1. Explique de qué manera interactúan las amenazas, vulnerabilidades y riesgos en un sistema informático. Incluya ejemplos concretos, describa cómo se evalúa el nivel de riesgo y qué controles preventivos y correctivos puede aplicar una organización para reducirlo.
   Interacción: Una **amenaza** es cualquier evento (accidental o intencionado) que puede causar daño. Una **vulnerabilidad** es una debilidad en el sistema (software, hardware o procedimental). El **riesgo** es la probabilidad de que una amenaza explote una vulnerabilidad causando un impacto negativo.
   Ejemplo: Un servidor sin actualizar (Vulnerabilidad) es atacado por un virus (Amenaza), lo que resulta en pérdida de datos (Riesgo materializado/Impacto)
   Evaluación: Se deben identificar los activos, sus vulnerabilidades y amenazas, calculando su probabilidad e impacto (financiero o administrativo)
   Controles: se aplican para aceptar, disminuir, transferir o evitar el riesgo. Pueden ser preventivos (actualizaciones), detectivos (auditorías) o correctivos (backups).

2. Describe los tres principios básicos de la seguridad informática (CIA).
Indica qué ocurre cuando cada uno se ve afectado.

- **Confidencialidad:** Garantiza que la información solo sea accesible por personas autorizadas. *Afectación:* Un atacante accede a datos privados o se interceptan mensajes en la red.
- **Integridad:** asegura que la información no sea alterada sin autorización. Afectación: Un usuario no autorizado modifica archivos o bases de datos.
- **Disponibilidad:** Asegura que la información y los sistemas estén accesibles cuando se necesiten. *Afectación:* Un ataque o fallo técnico impide que los usuarios usen el sistema.

3. ¿Por qué la autenticación y la autorización no significan lo mismo, y qué errores comunes ocurren en la implementación de sistemas de acceso?
Diferencia: la **AUTENTICACIÓN** verifica la identidad del usuario (quién es), mientras que la **AUTORIZACIÓN** (control de acceso) determina a qué recursos puede acceder una vez identificado.
Errores comunes: uso de contraseñas débiles o predecibles, configuraciones predeterminadas inseguras, y no revocar permisos de usuarios antiguos o cuentas obsoletas.

5. ¿Qué rol cumplen los IDS/IPS en la defensa de una red, y qué tipo de amenazas pueden detectar?
Rol: Forman parte de las metodologías de mitigación para problemas de disponibilidad y acceso no autorizado. Funcionan monitoreando la red para detectar actividades sospechosas.
Amenazas: Ayudan a detectar y mitigar ataques como los DDoS (Denegación de Servicio) e intentos de intrusión o accesos anómalos.

6. ¿Qué diferencia existe entre una amenaza, una vulnerabilidad y un riesgo en seguridad informática?

- Amenaza: Es la causa potencial de un daño (ej. un hacker, un incendio).
- Vulnerabilidad: Es la debilidad interna que permite el daño (ej. falta de antivirus, puerta abierta).
- Riesgo: Es la probabilidad de que la amenaza aproveche la vulnerabilidad.
- Fórmula conceptual: Riesgo = Amenaza x Vulnerabilidad x Impacto.

7 ¿Cómo garantizan los principios de la triada CIA (Confidencialidad, Integridad y Disponibilidad) la protección de la información dentro de un sistema?

- La Confidencialidad se protege mediante cifrado y controles de acceso para evitar fugas.
- La Integridad se protege mediante permisos de escritura estrictos y sumas de verificación (hash) para evitar modificaciones.
- La Disponibilidad se protege mediante redundancia de hardware, backups y planes de contingencia para asegurar el servicio.

8. ¿Cuáles son los principales problemas de seguridad en aplicaciones (SQL Injection, XSS, Buffer Overflow) y qué metodologías se recomiendan para mitigarlos?

- Inyección SQL: Manipulación de consultas a base de datos. Mitigación: Validación y saneamiento de entradas, uso de "prepared statements".
- XSS (Cross-Site Scripting): Inserción de scripts maliciosos en webs. Mitigación: Validación de entradas de usuario.
- Buffer Overflow: Exceso de datos que permite ejecutar código arbitrario. Mitigación: Revisiones de código y auditorías.

9. ¿Qué medidas componen la seguridad física y por qué es indispensable para la protección de la infraestructura informática?

Medidas: Control de acceso físico a servidores (cerraduras, vigilancia), sistemas de alarma y CCTV, y protección ambiental contra desastres (extintores, climatización, UPS para energía)

Es fundamental porque su función específica es **velar por que los equipos funcionen adecuadamente y anticiparse a casos de fallos, robos, incendios, sabotajes y desastres naturales**

10. ¿Qué es la autenticación multifactor (MFA) y cómo contribuye a disminuir accesos no autorizados?

- Definición: Método que exige dos o más factores de verificación para acceder.
- Factores: Algo que sabes (contraseña), algo que tienes (token/móvil), algo que eres (biometría).
- Beneficio: Reduce drásticamente el acceso no autorizado porque, aunque roben la contraseña, el atacante no posee el segundo factor físico o biométrico.

11. ¿Qué es un ataque DDoS y qué estrategias se utilizan para mantener la disponibilidad del sistema frente a este tipo de amenazas?

- Definición: Intento de hacer inaccesible un servidor saturándolo con tráfico abrumador desde múltiples puntos.
- Estrategias: Implementar firewalls y sistemas de detección de intrusos, usar balanceo de carga para distribuir el tráfico y tener redundancia de hardware

12. ¿Qué medidas deben incluirse en un Plan de Recuperación ante Desastres (DRP) y por qué es esencial para garantizar la continuidad operativa?

- Evaluación y Planificación: Análisis previo.
- Recuperación: Procedimientos operativos durante el desastre (ej. restaurar backups).
- Pruebas: Realización de simulacros continuos.
- Medidas técnicas: Redundancia y almacenamiento distribuido.

´ Porque garantizan siempre estar atentos a cualquier ataque, y en caso de sufrir un ataque tener un respaldo de datos con el backup.

13. ¿Cómo funciona la ingeniería social y cuáles son las técnicas más comunes utilizadas para manipular a los usuarios?
Funcionamiento: Manipulación psicológica para engañar a las personas y que revelen información confidencial o realicen acciones inseguras. Explota la naturaleza humana, no fallos técnicos.
Técnicas:

- Phishing: Correos masivos fraudulentos.
- Pretexting: Crear un escenario falso para ganar confianza.
- Baiting: Dejar dispositivos infectados (ej. USB) para que alguien los conecte.

14. ¿Cuál es el rol del control de acceso basado en roles (RBAC) dentro de un sistema informático y cómo evita accesos indebidos?
Su **función** es mitigar el acceso no autorizado asignando permisos según la función del usuario en la organización, no por individuo.
Evita accesos indebidos asegurando que cada **usuario solo tenga los privilegios** necesarios para su trabajo (principio de mínimo privilegio).

15. ¿Qué componentes debe incluir una política de seguridad informática dentro de una organización para ser efectiva?

- Debe incluir una declaración de intenciones de alto nivel, reglas y procedimientos para servicios críticos.
- Debe definir responsabilidades, acciones a ejecutar, clasificación de activos según su criticidad y programas de concientización para el personal.

16. ¿Cuál es la diferencia fundamental entre cifrado simétrico (AES) y asimétrico (RSA) y en qué situaciones se recomienda utilizar cada uno?

- Simétrico (ej. AES): Usa la misma clave para cifrar y descifrar. Es rápido, pero inseguro si hay que compartir la clave.
- Asimétrico (ej. RSA): Usa un par de claves (Pública para cifrar, Privada para descifrar). Es más seguro para la comunicación, pero más lento.

17. ¿Cómo garantiza la firma digital la autenticidad, integridad y no repudio de un documento, y qué rol cumplen los certificados digitales en este proceso?

- La firma digital utiliza cifrado asimétrico.
- Integridad: Asegura que el documento no fue modificado.
- Autenticidad y No Repudio: Garantiza que el origen es genuino y el emisor no puede negar haberlo enviado.
- Certificados Digitales: Los certificados (basados en cifrado) validan la identidad del firmante y demuestran la integridad y el origen de la información.

18. ¿Qué es un hash criptográfico y por qué es fundamental para garantizar la integridad de los datos en sistemas y aplicaciones?
Aunque los textos no definen técnicamente el algoritmo matemático del hash en profundidad, explican su función en la Integridad.
Es fundamental porque permite verificar que la información no ha sido alterada; si un archivo se modifica (aunque sea un bit), su "huella" o integridad se rompe. Se utiliza para almacenar contraseñas de forma segura y verificar que los archivos no tengan virus o modificaciones

Parte 1: Preguntas de Opción Múltiple (Respuestas y justificación breve)

1. ¿Qué garantiza el principio de confidencialidad en la seguridad informática?

- **Respuesta: b) Que solo usuarios autorizados puedan acceder a la información.**
- **Justificación:** La confidencialidad asegura que la información solo sea accesible e interpretada por personas o sistemas autorizados.

2. ¿Cuál de los siguientes ejemplos corresponde a una amenaza física?

- **Respuesta: b) Un incendio en el centro de datos.**
- **Justificación:** Las amenazas físicas afectan directamente al hardware y la infraestructura, incluyendo desastres naturales, incendios o robos.

3. ¿Qué tipo de ataque se basa en engañar a las personas para obtener información confidencial?

- **Respuesta: a) Ingeniería social.**
- **Justificación:** Se define como el uso de técnicas de manipulación psicológica para que los usuarios revelen información confidencial o realicen acciones inseguras.

4. ¿Qué herramienta o medida sirve para proteger una red filtrando el tráfico no autorizado?

- **Respuesta: b) Firewall.**
- **Justificación:** Un firewall actúa como barrera que monitorea, filtra y controla el tráfico de red entrante y saliente según reglas de seguridad .

5. ¿Cuál es la función del análisis de riesgos informáticos?

- **Respuesta: a) Identificar vulnerabilidades y establecer controles para reducir riesgos.**
- **Justificación:** Su objetivo es identificar activos, amenazas y vulnerabilidades para determinar los controles adecuados que disminuyan o eviten el riesgo.

Parte 2: Preguntas de Respuesta Corta (Concisas)

6. ¿Qué diferencia hay entre una amenaza interna y una externa? La **amenaza interna** proviene de dentro de la organización (empleados, personal técnico o ex-empleados) y representa entre el 60% y 80% de los incidentes. La **amenaza externa** proviene de fuera de la red (hackers, internet) .

7. Menciona tres tipos de malware. Virus, Gusanos (Worms) y Troyanos. (También son válidos: Ransomware, Spyware, Adware) .

8. ¿Qué se entiende por disponibilidad en seguridad informática? Es la garantía de que la información y los sistemas están operativos y accesibles en el momento adecuado para los usuarios legítimos que los necesitan.

9. ¿Qué es un ataque DDoS? Es un ataque de **Denegación Distribuida de Servicio** que consiste en saturar un servidor o red con una cantidad abrumadora de peticiones desde múltiples puntos para que deje de funcionar y sea inaccesible.

10. Explica brevemente qué es autenticación multifactor (MFA). Es un método de seguridad que exige al usuario presentar dos o más factores de verificación distintos para acceder (algo que sabes, algo que tienes, o algo que eres), dificultando el acceso no autorizado.

11. ¿Qué significa integridad de la información? Significa asegurar que la información no ha sido alterada y que solo puede ser modificada por personas autorizadas y de manera controlada.

12. Da un ejemplo de una medida de seguridad física. La instalación de cerraduras electrónicas, sistemas de alarma y CCTV (cámaras de seguridad) para controlar el acceso físico a los servidores.

13. ¿Qué es phishing? Es el envío de correos electrónicos o mensajes fraudulentos que simulan provenir de una entidad legítima (como un banco) para engañar al usuario y robar datos confidenciales.

14. Menciona dos buenas prácticas para proteger una red Wi-Fi doméstica.

1. Usar un cifrado fuerte (WPA2 o WPA3).
2. Cambiar la contraseña por defecto y las credenciales de acceso al router .

15. ¿Qué incluye una política de seguridad informática dentro de una organización? Incluye una declaración de intenciones de alto nivel, reglas y procedimientos para servicios críticos, definición de responsabilidades y la clasificación de los activos a proteger.